

# TechStore

## Políticas de Segurança da Informação (PSI-II)

|                           |                                                                                                                     |
|---------------------------|---------------------------------------------------------------------------------------------------------------------|
| <b>Documento</b>          | Políticas de Segurança da Informação (PSI-II)<br>Sistema de e-commerce (TechStore)                                  |
| <b>Versão</b>             | 1.0                                                                                                                 |
| <b>Classificação</b>      | Interno                                                                                                             |
| <b>Autores</b>            | Gabriel Alves; Gabriel Lopes Pereira; Luiz Mário Fontes da Silva Filho; Sidnei Barcelos                             |
| <b>Aprovação</b>          | Coordenação de Segurança da Informação                                                                              |
| <b>Data de elaboração</b> | 07/06/2026                                                                                                          |
| <b>Início da vigência</b> | 12/06/2026                                                                                                          |
| <b>Próxima revisão</b>    | 12/06/2027, revisão anual ou sempre que houver alteração relevante nos sistemas, processos ou legislação aplicável. |

### Aviso de Confidencialidade e Regra de Compartilhamento

Este documento é classificado como “Interno” e destina-se exclusivamente aos colaboradores, prestadores de serviço e parceiros autorizados da TechStore. É proibida a sua reprodução, divulgação, encaminhamento ou compartilhamento, total ou parcial, com terceiros ou por canais não corporativos, sem autorização formal do Comitê de Segurança da Informação. O descumprimento sujeita o responsável às penalidades previstas nas políticas deste documento.

# Sumário

|                                                                           |           |
|---------------------------------------------------------------------------|-----------|
| <b>Descrição do Cenário.....</b>                                          | <b>1</b>  |
| <b>Política de Controle de Acesso ao Sistema Administrativo (MFA)....</b> | <b>2</b>  |
| <b>Política de Armazenamento Seguro de Dados de Clientes.....</b>         | <b>4</b>  |
| <b>Política de Descarte de dados obsoletos.....</b>                       | <b>6</b>  |
| <b>Política de Senha.....</b>                                             | <b>8</b>  |
| <b>Política de Uso de Redes Sociais para Atendimento ao Cliente.....</b>  | <b>10</b> |
| <b>Política de Prevenção e Resposta a Vazamento de Dados.....</b>         | <b>12</b> |
| <b>Política de Prevenção à Manipulação de Informações.....</b>            | <b>14</b> |
| <b>Utilização de Inteligência artificial.....</b>                         | <b>17</b> |
| <b>Termo de Ciência e Consentimento.....</b>                              | <b>17</b> |

## Descrição do Cenário

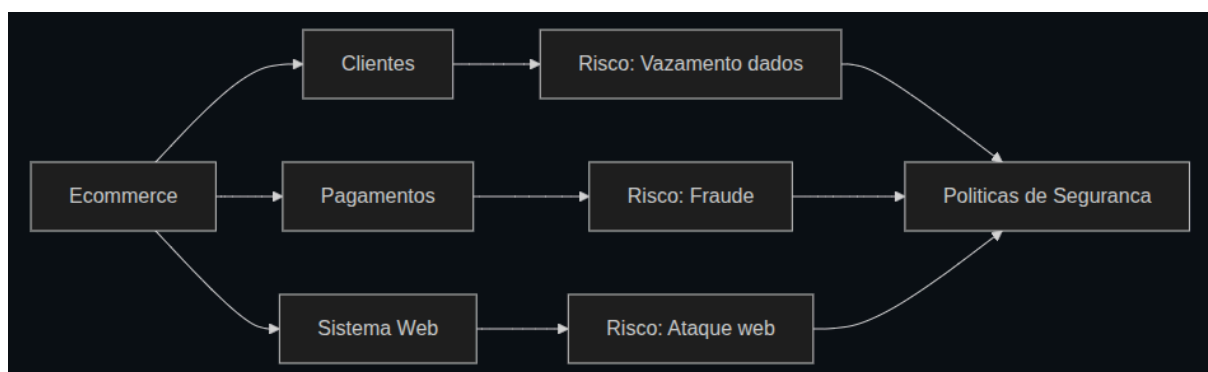
A TechStore é uma loja virtual de pequeno porte que comercializa produtos eletrônicos e acessórios de informática exclusivamente por meio de seu site na internet. A empresa opera no modelo B2C (venda direta ao consumidor) e conta com uma equipe enxuta de aproximadamente 15 funcionários, distribuídos entre os setores administrativo, de atendimento ao cliente, logística e tecnologia da informação.

Para realizar suas vendas, a TechStore mantém uma plataforma de e-commerce que armazena e processa dados pessoais dos clientes, tais como nome completo, CPF, endereço, telefone, e-mail e histórico de compras. Os dados de pagamento são processados por meio de um gateway terceirizado, mas o histórico de transações dos clientes fica registrado no sistema da empresa.

O ambiente tecnológico é composto por:

- Um site/loja virtual acessível ao público, onde os clientes realizam cadastro, navegam pelos produtos e efetuam compras.
- Um sistema administrativo de acesso restrito, utilizado pelos funcionários para gerenciar pedidos, estoque, cadastros de clientes e relatórios.
- Um banco de dados que centraliza as informações pessoais e o histórico de compras dos clientes.
- Canais de redes sociais (como Instagram e WhatsApp) utilizados para atendimento ao cliente e divulgação de produtos.

Por lidar diariamente com grande volume de dados pessoais, a TechStore está sujeita às exigências da Lei Geral de Proteção de Dados (LGPD) e identifica como principais riscos à sua operação o vazamento de dados de clientes, a fraude em pagamentos, a manipulação indevida de informações e os ataques à aplicação web. Diante desse contexto, torna-se necessária a elaboração de políticas de segurança da informação que orientem o comportamento dos funcionários e protejam os ativos de informação da empresa.



# Política de Controle de Acesso ao Sistema Administrativo (MFA)

**Objetivo:** Estabelecer regras para a concessão, o uso, a revisão e a revogação de acessos ao sistema administrativo da TechStore, exigindo autenticação multifator (MFA) para todo acesso, com o intuito de impedir o acesso não autorizado, o uso indevido das credenciais e o comprometimento dos dados pessoais de clientes tratados no ambiente restrito.

**Escopo:** Aplica-se a todos os funcionários, prestadores de serviço e colaboradores que acessem o sistema administrativo, o banco de dados, relatórios ou qualquer função de gestão de pedidos, estoque e cadastros de clientes da TechStore.

## Regras:

1. O acesso ao sistema administrativo só é permitido mediante credencial individual e intransferível combinada com MFA. Não é permitido qualquer acesso administrativo apenas com usuário e senha.
2. Cada usuário deve registrar pelo menos dois fatores de autenticação distintos, com preferência a aplicativo autenticador ou código numérico encaminhado via email.
3. A concessão de acessos segue o princípio do menor privilégio e a segregação de funções: cada usuário acessa somente as informações e operações necessárias à sua função.
4. O acesso privilegiado é restrito ao setor de TI/Segurança, concedido de forma nominal, formalmente aprovado e revisado periodicamente.
5. Os direitos de acesso devem ser revisados a cada 6 meses e revogados imediatamente no desligamento, transferência ou mudança de função do colaborador.
6. Após 3 tentativas de autenticação mal sucedidas, a conta deve ser bloqueada temporariamente.
7. Sessões inativas devem expirar automaticamente após período definido pela TI, forçando o usuário a realizar uma nova autenticação.
8. Todos os acessos e tentativas de acesso ao sistema administrativo devem gerar logs de auditoria (usuário, data, hora e ação), preservados e sem possibilidade de alteração.
9. É proibido compartilhar contas, fatores de autenticação, dispositivos ou códigos de MFA. A perda ou suspeita de comprometimento de um fator deve ser comunicada imediatamente à equipe de TI para reset.
10. A recuperação de acesso e o reset de MFA só podem ocorrer por procedimento formal de verificação de identidade conduzido pela equipe de TI.

**Penalidades:** O descumprimento desta política, desde que o funcionário tenha tido ciência prévia dela por meio de treinamento, assinatura de termo de ciência ou divulgação formal, poderá acarretar, conforme a gravidade: advertência verbal, advertência por escrito, suspensão e demissão por justa causa. Casos de compartilhamento doloso de credenciais, acesso não autorizado ou exposição de dados de clientes poderão gerar responsabilização civil e criminal, além das sanções previstas na LGPD.

| Item             | Informação                                                                          |
|------------------|-------------------------------------------------------------------------------------|
| <b>Autoria</b>   | Luiz Mário Fontes da Silva Filho - Setor de TI/Segurança da Informação - 07/06/2026 |
| <b>Versão</b>    | 1.0                                                                                 |
| <b>Aprovação</b> | Coordenação de Segurança da Informação - 11/06/2026                                 |
| <b>Vigência</b>  | A partir de 12/06/2026, com validade até 12/06/2027 (sujeita a revisão anual)       |
| <b>Contato</b>   | luiz.fontes@techstore.com.br                                                        |

## Política de Armazenamento Seguro de Dados de Clientes

**Objetivo:** Estabelecer regras e controles para o armazenamento seguro dos dados pessoais dos clientes da TechStore, por meio do uso de criptografia e de medidas complementares de proteção, garantindo a confidencialidade e a integridade dessas informações, prevenindo o vazamento de dados e atendendo às exigências da Lei Geral de Proteção de Dados (LGPD).

**Escopo:** Delimita-se a todos os dados pessoais de clientes armazenados nos ambientes da TechStore, como banco de dados da loja virtual, sistema administrativo, backups, relatórios e arquivos autorizados e a todos os funcionários, prestadores de serviço e fornecedores de tecnologia que participem do tratamento dessas informações.

### Regras:

1. Todos os dados pessoais de clientes devem ser armazenados de forma criptografada no banco de dados utilizando o algoritmo de criptografia AES-256.
2. Toda a comunicação entre o navegador do cliente e a loja virtual deve ser criptografada em trânsito por meio de HTTPS (protocolo TLS 1.2 ou superior), com certificado digital válido em todas as páginas do site.

3. As senhas de clientes e de funcionários nunca devem ser armazenadas em texto claro ou de forma reversível. Devem ser protegidas com função de hash bcrypt.
4. A TechStore não deve armazenar dados completos de cartão de pagamento, o processamento é realizado exclusivamente pelo gateway de pagamento terceirizado, ficando registrado no sistema da empresa apenas o histórico das transações.
5. As chaves de criptografia devem ser guardadas separadas dos dados que protegem, em local seguro definido pela equipe de TI, com acesso restrito e troca imediata em caso de suspeita de comprometimento.
6. Os backups que contenham dados de clientes devem ser criptografados com o algoritmo de criptografia AES-256 e armazenados em local distinto do sistema principal.
7. É proibido copiar ou armazenar dados de clientes em texto claro fora do banco de dados oficiais, como em planilhas, e-mails, pendrives, dispositivos pessoais ou serviços de nuvem não autorizados pela empresa.
8. Dados sensíveis, como o CPF, devem aparecer mascarados nas telas e nos relatórios do sistema sempre que a visualização completa não for necessária à função do usuário.
9. Ambientes de teste e de desenvolvimento não devem utilizar dados reais de clientes.
10. O acesso ao banco de dados segue o princípio do menor privilégio e as regras da Política de Controle de Acesso ao Sistema Administrativo (MFA), com registro das operações em logs de auditoria.
11. Dados de clientes que se tornarem obsoletos devem ser encaminhados ao descarte seguro, conforme política específica de descarte de dados.
12. A equipe de TI deve verificar periodicamente se a criptografia está ativa e se o certificado digital do site está válido, registrando o resultado dessas verificações.

**Penalidades:** O descumprimento desta política, desde que o funcionário tenha tido ciência prévia dela por meio de treinamento, assinatura de termo de ciência ou divulgação formal, poderá acarretar, conforme a gravidade: advertência verbal, advertência por escrito, suspensão e demissão por justa causa. Casos de compartilhamento doloso de credenciais, acesso não autorizado ou exposição de dados de clientes poderão gerar responsabilização civil e criminal, além das sanções previstas na LGPD.

#### Tabela de Riscos

| ID | Risco                                            | Probabilidade | Impacto | Nível | Ação                                                              |
|----|--------------------------------------------------|---------------|---------|-------|-------------------------------------------------------------------|
| 1  | Vazamento de dados por invasão ao banco de dados | Média         | Alto    | Alto  | Criptografia com algoritmo (AES-256) e controle de acesso com MFA |

| ID | Risco                                                                 | Probabilidade | Impacto | Nível   | Ação                                                      |
|----|-----------------------------------------------------------------------|---------------|---------|---------|-----------------------------------------------------------|
| 2  | Interceptação de dados entre o cliente e o site                       | Média         | Alto    | Alto    | HTTPS (TLS 1.2) obrigatório em todas as páginas           |
| 3  | Exposição de senhas de clientes em caso de invasão                    | Média         | Alto    | Alto    | Função de Hash bcrypt                                     |
| 4  | Comprometimento das chaves de criptografia                            | Baixa         | Alto    | Médio   | Chaves guardadas separadas dos dados, com acesso restrito |
| 5  | Vazamento por backup perdido ou desprotegido                          | Média         | Alto    | Alto    | Backup criptografado e guardado em local distinto         |
| 6  | Cópia de dados em texto claro para planilhas ou dispositivos pessoais | Alta          | Alto    | Crítico | Proibição formal, treinamento e auditoria periódica       |

| Item             | Informação                                                                    |
|------------------|-------------------------------------------------------------------------------|
| <b>Autoria</b>   | Gabriel Alves - Setor de TI/Segurança da Informação - 08/06/2026              |
| <b>Versão</b>    | 1.0                                                                           |
| <b>Aprovação</b> | Coordenação de Segurança da Informação - 11/06/2026                           |
| <b>Vigência</b>  | A partir de 12/06/2026, com validade até 12/06/2027 (sujeita a revisão anual) |
| <b>Contato</b>   | gabriel.alves@techstore.com.br                                                |

## Política de Descarte de dados obsoletos

**Objetivo:** Estabelecer regras para a identificação e o descarte seguro de dados de clientes que se tornaram obsoletos na TechStore, garantindo que informações que não são mais necessárias sejam eliminadas de forma definitiva e irrecuperável, evitando vazamento de dados e atendendo às exigências da Lei Geral de Proteção de Dados (LGPD) quanto ao término do tratamento.

**Escopo:** Aplica-se a todos os dados de clientes armazenados nos sistemas da TechStore (banco de dados, backups, relatórios e arquivos), aos documentos impressos que contenham dados de clientes e aos equipamentos e mídias de armazenamento da empresa (computadores, HDs, pendrives), abrangendo todos os funcionários e prestadores de serviço.

**Regras:**

1. A TechStore deve manter uma tabela de prazos, definindo por quanto tempo cada tipo de dado de cliente é mantido, considerando a finalidade do negócio e as obrigações legais.
2. A equipe de TI deve realizar, no mínimo uma vez por ano, uma revisão para identificar dados obsoletos.
3. Quando o cliente solicitar a eliminação dos seus dados pessoais, a TechStore deve atender ao pedido, exceto quanto aos dados que a lei obriga a conservar, nesse caso, o cliente deve ser informado do motivo da conservação.
4. Nenhum dado deve ser descartado por iniciativa individual. Todo descarte deve ser autorizado pela equipe de TI/Segurança, evitando tanto a exclusão indevida de dados ainda necessários quanto a retenção de dados obsoletos.
5. A exclusão de dados nos sistemas deve ser definitiva e irreversível. Apenas mover registros para a lixeira ou inativar o cadastro não é considerado descarte.
6. Backups vencidos que contenham dados já descartados devem ser destruídos ou sobrescritos ao final do seu prazo de retenção.
7. Dados úteis para estatísticas e análises do negócio podem ser mantidos de forma anonimizada, em vez de eliminados.
8. Equipamentos e mídias de armazenamento (computadores, HDs, pendrives) só podem ser descartados, doados ou reutilizados após sobrescrita segura dos dados ou destruição física da mídia. A formatação comum não é suficiente, pois os dados continuam recuperáveis.
9. Documentos impressos com dados de clientes devem ser triturados antes do descarte.
10. Se o descarte for realizado por empresa terceirizada deve haver contrato e emissão de comprovante de destruição.
11. Todo descarte deve ser registrado em um termo de descarte, informando o que foi descartado, quando, de que forma e por quem, para fins de auditoria e prestação de contas.
12. É proibido descartar no lixo comum, vender ou doar qualquer equipamento, mídia ou documento que contenha dados de clientes sem o apagamento ou a destruição segura prévia.

**Penalidades:** O descumprimento desta política, desde que o funcionário tenha tido ciência prévia dela por meio de treinamento, assinatura de termo de ciência ou divulgação formal, poderá acarretar, conforme a gravidade: advertência verbal, advertência por escrito, suspensão e demissão por justa causa. Casos de descarte irregular que resultem em exposição de dados de clientes poderão gerar responsabilização civil e criminal, além das sanções previstas na LGPD.



| ID | Risco                                                           | Probabilidade | Impacto | Nível | Ação                                                 |
|----|-----------------------------------------------------------------|---------------|---------|-------|------------------------------------------------------|
| 1  | Venda ou doação de computador/HD antigo com dados recuperáveis  | Média         | Alto    | Alto  | Sobrescrita segura ou destruição física da mídia     |
| 2  | Etiquetas de envio e relatórios impressos jogados no lixo comum | Alta          | Médio   | Alto  | Trituração de papel antes do descarte                |
| 3  | Dados mantidos além do prazo necessário                         | Média         | Alto    | Alto  | Tabela de prazos de retenção e revisão anual         |
| 4  | Dado "excluído" ainda recuperável no sistema ou em backups      | Média         | Alto    | Alto  | Exclusão definitiva e destruição de backups vencidos |
| 5  | Exclusão acidental ou indevida de dados ainda necessários       | Média         | Alto    | Alto  | Descarte somente com autorização da TI               |
| 6  | Descarte sem registro                                           | Média         | Médio   | Médio | Termo de descarte registrando cada operação          |

| Item             | Informação                                                                    |
|------------------|-------------------------------------------------------------------------------|
| <b>Autoria</b>   | Gabriel Alves - Setor de TI/Segurança da Informação - 08/06/2026              |
| <b>Versão</b>    | 1.0                                                                           |
| <b>Aprovação</b> | Coordenação de Segurança da Informação - 11/06/2026                           |
| <b>Vigência</b>  | A partir de 12/06/2026, com validade até 12/06/2027 (sujeita a revisão anual) |
| <b>Contato</b>   | gabriel.alves@techstore.com.br                                                |

## Política de Senha

**Objetivo:** Definir os requisitos mínimos de criação, uso, armazenamento e troca de senhas na TechStore, assegurando que as credenciais sejam robustas e protegidas contra adivinhação, força bruta e vazamento, em complemento à Política de Controle de Acesso (MFA).

**Escopo:** Aplica-se a todas as senhas de usuários e contas de serviço utilizadas para acessar o sistema administrativo, o banco de dados, as contas corporativas de redes sociais e quaisquer sistemas internos da TechStore.

## Regras:

1. Toda senha deve ter, no mínimo, 12 caracteres, combinando letras maiúsculas, minúsculas, números e caracteres especiais.
2. Toda senha deve ser trocada a cada 3 meses.
3. É proibido o uso de senhas óbvias ou previsíveis (nome, CPF, data de nascimento, "123456", "senha", nome da empresa) e de senhas idênticas às já utilizadas em sistemas pessoais.
4. As senhas são individuais e intransferíveis. Não é permitido compartilhá-las, anotá-las em locais visíveis ou armazená-las em texto claro (planilhas, e-mails, cadernos).
5. A senha deve ser trocada no primeiro acesso, após o fornecimento da senha temporária disponibilizada pela equipe de TI.
6. As senhas devem ser trocadas imediatamente sempre que houver evidência de comprometimento.
7. É proibido reutilizar as últimas 5 senhas e reaproveitar a mesma senha em sistemas distintos.
8. As senhas devem ser guardadas exclusivamente em cofre de senhas corporativo aprovado pela TI, sendo vedado salvá-las no navegador ou em qualquer outro local não autorizado.
9. Após 3 tentativas incorretas, a conta deve ser temporariamente bloqueada, e o evento registrado em log.
10. Senhas temporárias e de redefinição devem ter validade curta (12 horas), ser de uso único e enviadas por canal seguro.
11. A senha isoladamente não substitui o MFA, que permanece obrigatório no acesso administrativo.

**Penalidades:** O descumprimento desta política, desde que o funcionário tenha tido ciência prévia dela por meio de treinamento, termo de ciência ou divulgação formal, poderá resultar, conforme a gravidade: advertência verbal, advertência por escrito, suspensão e demissão por justa causa. O compartilhamento doloso de senhas ou a exposição que resulte em acesso indevido a dados de clientes poderá ainda gerar responsabilização civil e criminal e as sanções da LGPD.

## Tabela de Riscos

| ID | Risco                           | Probabilidade | Impacto | Nível | Ação                                    |
|----|---------------------------------|---------------|---------|-------|-----------------------------------------|
| 1  | Quebra de senha por força bruta | Baixa         | Alto    | Médio | Mínimo de 12 caracteres com complexidad |

|   |                                                                    |       |      |         |                                                             |
|---|--------------------------------------------------------------------|-------|------|---------|-------------------------------------------------------------|
|   |                                                                    |       |      |         | e e bloqueio após 3 tentativas.                             |
| 2 | Compartilhamento de senha entre funcionários                       | Alta  | Alto | Crítico | Senhas individuais e assinatura do termo de ciência.        |
| 3 | Exposição de senha anotada em texto claro                          | Média | Alto | Alto    | Proibição de anotação em texto.                             |
| 4 | Comprometimento por reutilização da mesma senha em vários sistemas | Média | Alto | Alto    | Proibição de reutilização e histórico mínimo de 5 senhas.   |
| 5 | Adivinhação de senha baseada em dados pessoais                     | Média | Alto | Alto    | Proibição de senhas previsíveis, utilizando dados pessoais. |
| 6 | Comprometimento da senha devido a não alteração                    | Baixa | Alto | Médio   | Alteração obrigatória de senha após o período de 3 meses.   |

| Item             | Informação                                                                          |
|------------------|-------------------------------------------------------------------------------------|
| <b>Autoria</b>   | Luiz Mário Fontes da Silva Filho - Setor de TI/Segurança da Informação - 08/06/2026 |
| <b>Versão</b>    | 1.0                                                                                 |
| <b>Aprovação</b> | Coordenação de Segurança da Informação - 11/06/2026                                 |
| <b>Vigência</b>  | A partir de 12/06/2026, com validade até 12/06/2027 (sujeita a revisão anual)       |
| <b>Contato</b>   | luiz.fontes@techstore.com.br                                                        |

# Política de Uso de Redes Sociais para Atendimento ao Cliente

**Objetivo:** Estabelecer regras para o uso dos canais de redes sociais (Instagram, WhatsApp, Facebook e similares) no atendimento ao cliente da TechStore, garantindo a proteção dos dados pessoais dos clientes, a padronização da comunicação e a prevenção de vazamento ou exposição indevida de informações nesses canais.

**Escopo:** Aplica-se a todos os funcionários do setor de Atendimento ao Cliente e a qualquer colaborador autorizado a operar as contas oficiais da empresa nas redes sociais.

## Regras:

1. Apenas funcionários formalmente autorizados pelo setor de Atendimento podem acessar e responder pelas contas oficiais da empresa.
2. As credenciais de acesso às contas de redes sociais são corporativas e não podem ser compartilhadas com terceiros nem utilizadas para fins pessoais.
3. É proibido solicitar ou receber dados sensíveis dos clientes (CPF completo, senha, dados de cartão de pagamento) por meio de redes sociais. Esses dados, quando necessários, devem ser tratados em canais seguros próprios do sistema.
4. Conversas que envolvam dados pessoais devem ser conduzidas em mensagens privadas (DM), nunca em comentários ou publicações públicas.
5. É vedado divulgar prints, capturas de tela ou qualquer informação de clientes em postagens, grupos ou canais externos.
6. O atendente deve manter uma linguagem cordial e profissional, representando oficialmente a empresa.
7. Reclamações e dados de clientes obtidos via redes sociais devem ser registrados no sistema administrativo para rastreabilidade.
8. O atendimento pelas redes sociais deve restringir-se ao horário comercial definido pela empresa, e respostas automáticas devem informar o prazo de retorno fora desse período.
9. É proibido clicar em links, baixar arquivos ou abrir anexos enviados por clientes pelas redes sociais sem verificação prévia, a fim de prevenir golpes de engenharia social e contaminação por malware nos dispositivos corporativos.
10. Solicitações de exclusão de dados, reclamações formais ou questões jurídicas recebidas pelas redes sociais devem ser encaminhadas ao setor responsável pelo tratamento de dados, não podendo ser resolvidas exclusivamente pelo canal social.

**Penalidades:** O descumprimento desta política, desde que o funcionário tenha tido ciência prévia dela (via treinamento e divulgação formal), poderá acarretar, conforme a gravidade: advertência verbal, advertência por escrito, suspensão e, em casos graves (como exposição

de dados de clientes), demissão por justa causa e responsabilização civil/criminal nos termos da LGPD.

### Tabela de Riscos

| ID | Risco                                                                    | Probabilidade | Impacto | Nível | Ação                                                     |
|----|--------------------------------------------------------------------------|---------------|---------|-------|----------------------------------------------------------|
| 1  | Vazamento de dados de clientes em comentários ou publicações públicas    | Média         | Alto    | Alto  | Tratar dados apenas em mensagens privadas (DM)           |
| 2  | Uso indevido ou pessoal das contas corporativas                          | Média         | Médio   | Médio | Acesso restrito a autorizados e credenciais corporativas |
| 3  | Engenharia social, com golpista se passando por cliente para obter dados | Média         | Alto    | Alto  | Proibição de tratar dados sensíveis pelo canal social    |
| 4  | Compartilhamento de prints com dados de clientes em grupos externos      | Média         | Alto    | Alto  | Proibição formal de divulgar capturas de tela            |
| 5  | Malware ou phishing via links/anexos enviados por clientes               | Média         | Alto    | Alto  | Proibição de abrir links e anexos sem verificação        |
| 6  | Perda de rastreabilidade de atendimentos e solicitações                  | Alta          | Médio   | Alto  | Registro obrigatório no sistema administrativo           |

| Item             | Informação                                                                                                                                                             |
|------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Autoria</b>   | Sidnei Barcelos - Setor de TI/Segurança da Informação - 10/06/2026                                                                                                     |
| <b>Versão</b>    | 1.0                                                                                                                                                                    |
| <b>Aprovação</b> | Coordenação de Segurança da Informação - 11/06/2026                                                                                                                    |
| <b>Vigência</b>  | A partir de 12/06/2026, com validade até 12/06/2027, sujeita a revisão anual ou sempre que houver alteração relevante nos sistemas, processos ou legislação aplicável. |
| <b>Contato</b>   | sidnei.barcelos@techstore.com.br                                                                                                                                       |

# Política de Prevenção e Resposta a Vazamento de Dados

**Objetivo:** Estabelecer regras e procedimentos para prevenir, identificar, comunicar, conter e tratar incidentes de vazamento de dados pessoais na TechStore, protegendo as informações dos clientes e reduzindo riscos de fraudes, exposição indevida, danos à imagem da empresa e descumprimento da Lei Geral de Proteção de Dados.

**Escopo:** Esta política aplica-se a todos os funcionários, prestadores de serviço e colaboradores autorizados que tenham acesso ao sistema administrativo, banco de dados, relatórios, canais de atendimento, pedidos, cadastros de clientes ou qualquer informação pessoal tratada pela TechStore.

**Definição de vazamento de dados:** Considera-se vazamento de dados qualquer incidente que resulte em acesso, divulgação, alteração, perda, cópia, envio ou exposição não autorizada de dados pessoais de clientes, funcionários ou parceiros da TechStore. Isso inclui, por exemplo, envio de dados para destinatário incorreto, acesso indevido ao sistema administrativo, exposição de planilhas com dados de clientes, invasão ao banco de dados, roubo de credenciais, perda de dispositivos contendo informações da empresa ou publicação acidental de dados em canais públicos.

## Regras:

1. Todo funcionário que identificar ou suspeitar de vazamento de dados deverá comunicar imediatamente o setor de TI/Segurança da Informação ou o responsável pela proteção de dados da empresa.
2. É proibido ocultar, apagar evidências, tentar resolver sozinho ou deixar de comunicar qualquer suspeita de vazamento de dados.
3. Ao identificar um possível incidente, o setor de TI deverá registrar a ocorrência, contendo data, hora, sistema afetado, tipo de dado envolvido, usuários relacionados, possível causa e medidas iniciais adotadas.
4. O acesso ao sistema afetado poderá ser temporariamente bloqueado ou limitado para contenção do incidente, preservando logs, registros de acesso e demais evidências necessárias para investigação.
5. A empresa deverá avaliar a gravidade do incidente, considerando a quantidade de titulares afetados, o tipo de dado exposto, o risco de fraude, roubo de identidade, dano financeiro, dano moral ou dano reputacional aos clientes.
6. Caso o incidente possa gerar risco ou dano relevante aos titulares, a TechStore deverá comunicar a Autoridade Nacional de Proteção de Dados e os titulares afetados, conforme exigido pela LGPD e pelas normas vigentes.
7. A comunicação aos clientes deverá ser clara, objetiva e em linguagem simples, informando, quando aplicável, a natureza dos dados afetados, os riscos envolvidos,

as medidas adotadas pela empresa e as orientações para que o cliente possa se proteger.

8. Nenhum funcionário está autorizado a divulgar informações sobre incidentes de segurança para clientes, imprensa, redes sociais ou terceiros sem autorização formal da direção da empresa ou do setor responsável.
9. Após a contenção do incidente, a equipe de TI deverá realizar análise da causa raiz e propor medidas corretivas, como troca de senhas, revisão de permissões, atualização de sistemas, reforço de criptografia, treinamento de funcionários ou melhoria nos controles de acesso.
10. Todos os incidentes de segurança envolvendo dados pessoais deverão ser documentados e arquivados para fins de auditoria, prestação de contas e melhoria contínua dos processos de segurança da informação.
11. Os funcionários devem utilizar apenas sistemas, dispositivos e canais autorizados pela empresa para acessar, armazenar ou transmitir dados de clientes.
12. É proibido copiar dados de clientes para dispositivos pessoais, planilhas não autorizadas, contas pessoais de e-mail, aplicativos de mensagens privados ou serviços de armazenamento não aprovados pela empresa.

**Penalidades:** O descumprimento desta política, desde que o funcionário tenha tido ciência prévia dela por meio de treinamento, assinatura de termo de ciência ou divulgação formal, poderá resultar, conforme a gravidade: advertência verbal, advertência por escrito, suspensão e demissão por justa causa. Casos envolvendo ocultação de incidentes, exposição intencional de dados, venda de informações, fraude ou prejuízo a clientes poderão gerar responsabilização civil e criminal, além das sanções previstas na LGPD.

| Item             | Informação                                                                                                                                                             |
|------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Autoria</b>   | Gabriel Lopes Pereira — Setor de TI/Segurança da Informação — 10/06/2026                                                                                               |
| <b>Versão</b>    | 1.0                                                                                                                                                                    |
| <b>Aprovação</b> | Coordenação de Segurança da Informação - 11/06/2026                                                                                                                    |
| <b>Vigência</b>  | A partir de 12/06/2026, com validade até 12/06/2027, sujeita a revisão anual ou sempre que houver alteração relevante nos sistemas, processos ou legislação aplicável. |
| <b>Contato</b>   | gabriel.lopes@techstore.com.br                                                                                                                                         |

## Política de Prevenção à Manipulação de Informações

**Objetivo:** Garantir a integridade das informações armazenadas e processadas pela TechStore, prevenindo a alteração, exclusão ou inserção indevida de dados de clientes, pedidos, estoque e registros financeiros, sejam essas ações intencionais ou acidentais.

**Escopo:** Aplica-se a todos os funcionários com acesso ao sistema administrativo e ao banco de dados da empresa.

**Regras:**

1. Cada funcionário deve possuir credenciais individuais e intransferíveis; é proibido o uso de contas compartilhadas.
2. O acesso aos dados deve seguir o princípio do menor privilégio: cada usuário acessa apenas as informações necessárias à sua função.
3. Toda alteração relevante em registros (cadastros, pedidos, valores, estoque) deve ser feita exclusivamente pelo sistema administrativo, que registra logs de auditoria (autor, data, hora e ação realizada).
4. É proibido alterar, excluir ou inserir informações sem autorização ou justificativa registrada.
5. Os logs de auditoria não podem ser apagados ou modificados por usuários comuns e devem ser preservados para fins de rastreabilidade.
6. Auditorias periódicas devem ser realizadas pelo setor de TI para verificar a integridade dos registros e identificar acessos ou alterações suspeitas.
7. Backups regulares devem ser mantidos para permitir a restauração de dados em caso de manipulação ou perda.
8. Alterações críticas em registros financeiros, valores de pedidos ou cancelamentos devem exigir dupla verificação ou aprovação de um segundo responsável, evitando que uma única pessoa altere informações sensíveis sem supervisão.
9. A integridade dos dados deve ser verificável por meio de mecanismos de controle (como checksums, versionamento de registros ou comparação periódica com backups), permitindo identificar alterações não autorizadas.
10. É proibido executar comandos diretos no banco de dados que contornem o sistema administrativo e seus logs de auditoria; qualquer intervenção técnica excepcional deve ser previamente autorizada pela equipe de TI/Segurança e devidamente registrada.

**Penalidades:** A manipulação indevida de informações, desde que o funcionário tenha tido ciência prévia desta política, poderá resultar, conforme a gravidade: advertência por escrito, suspensão e demissão por justa causa. Casos que configurem fraude, adulteração de registros ou prejuízo à empresa ou a clientes poderão ainda gerar responsabilização civil e criminal.

**Tabela de Riscos**

| ID | Risco | Probabilidade | Impacto | Nível | Ação |
|----|-------|---------------|---------|-------|------|
|----|-------|---------------|---------|-------|------|



|   |                                                                         |       |      |       |                                                      |
|---|-------------------------------------------------------------------------|-------|------|-------|------------------------------------------------------|
| 1 | Alteração indevida de pedidos, valores ou estoque por funcionário       | Média | Alto | Alto  | Logs de auditoria e princípio do menor privilégio    |
| 2 | Uso de contas compartilhadas impedindo identificar o autor da alteração | Média | Alto | Alto  | Credenciais individuais e intransferíveis            |
| 3 | Exclusão ou adulteração de logs de auditoria                            | Baixa | Alto | Médio | Logs protegidos contra alteração por usuários comuns |
| 4 | Fraude financeira por alteração de valores sem supervisão               | Média | Alto | Alto  | Dupla verificação em alterações críticas             |
| 5 | Manipulação direta no banco de dados contornando o sistema              | Baixa | Alto | Médio | Proibição de comandos diretos sem autorização da TI  |
| 6 | Perda ou corrupção de dados sem possibilidade de restauração            | Média | Alto | Alto  | Backups regulares e verificação de integridade       |

| Item             | Informação                                                                                                                                                             |
|------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Autoria</b>   | Sidnei Barcelos - Setor de TI/Segurança da Informação - 10/06/2026                                                                                                     |
| <b>Versão</b>    | 1.0                                                                                                                                                                    |
| <b>Aprovação</b> | Coordenação de Segurança da Informação - 11/06/2026                                                                                                                    |
| <b>Vigência</b>  | A partir de 12/06/2026, com validade até 12/06/2027, sujeita a revisão anual ou sempre que houver alteração relevante nos sistemas, processos ou legislação aplicável. |
| <b>Contato</b>   | sidnei.barcelos@techstore.com.br                                                                                                                                       |

## Utilização de Inteligência artificial

Os autores declaram a utilização da inteligência artificial descrita abaixo para apoio na revisão, estruturação e correção do documento.

**Modelo utilizado:** Chat GPT

**Prompts utilizados:**

1. "Análise o documento e verifique os erros ortográficos e de formatação para padronizar todo o documento. Além disso, elimine a linguagem informal".
2. "Revisar a clareza e a redação de duas políticas de segurança que escrevi (Uso de Redes Sociais e Manipulação de Informações), sugerindo melhorias de coesão e padronização de linguagem formal, sem alterar o conteúdo técnico."
3. "Sugerir riscos adicionais relacionados ao uso de redes sociais no atendimento e à integridade de dados, para que eu avalie e inclua na tabela de riscos."
4. "Me ajude a achar possíveis regras que eu tenha esquecido de mencionar, mas que grandes e-commerces usam."
5. "Revise a tabela de riscos que fiz para a minha política, verificando se a classificação de probabilidade, impacto e nível está coerente entre os itens e se a ação descrita corresponde e faz sentido."

## Termo de Ciência e Consentimento

Declaro, para os devidos fins, que recebi, li e compreendi a Política de Segurança da Informação (PSI) da TechStore e as políticas específicas que a integram, relacionadas no sumário deste documento.

**Estou ciente e concordo que:**

- cumprir integralmente as regras e os procedimentos estabelecidos nas políticas, no exercício das minhas atividades;
- as credenciais e os acessos que me forem concedidos são individuais, intransferíveis e de uso exclusivamente profissional;
- devo tratar os dados pessoais de clientes e da empresa com confidencialidade, observando a LGPD (Lei nº 13.709/2018);
- este documento é de uso interno e não pode ser compartilhado, reproduzido ou encaminhado a terceiros sem autorização formal;
- o descumprimento das políticas poderá acarretar as penalidades nelas previstas (advertência verbal ou escrita, suspensão e demissão por justa causa), sem prejuízo da responsabilização civil e criminal cabível.

Manifesto minha concordância e comprometo-me a observar as referidas políticas a partir da data de assinatura deste termo.

**Nome completo:**

---

**Cargo / Setor:** \_\_\_\_\_

**Matrícula / CPF:** \_\_\_\_\_

**Local e data:** \_\_\_\_\_

\_\_\_\_\_  
Assinatura do colaborador